



Lecture 9

Computer Security Technology

Computer Security Technology - Encryption

- Encryption is the process of converting a plaintext message into a secure-coded form of text, called ciphertext.
- The ciphertext cannot be understood without converting back, via decryption—the reverse process—to plaintext.
- This is done via a mathematical function and a special encryption/decryption password called the key. In many countries, encryption is subject to governmental laws and regulations that limit the key size or define what may not be encrypted.
- Encryption is part of a broader science of secret languages called cryptography, which is generally used to:
 - Protect information stored on computers from unauthorized viewing and manipulation
 - Protect data in transit over networks from unauthorized interception and manipulation
 - Deter and detect accidental or intentional alterations of data
 - Verify authenticity of a transaction or document

Key Elements of Cryptographic Systems

- Key elements of cryptographic systems include:
 - Encryption algorithm—Mathematically based function or calculation that encrypts or decrypts data.
 - Encryption key—Piece of information similar to a password that makes the encryption or decryption process unique. A user needs the correct key to access or decipher a message, as the wrong key converts the message into an unreadable form.
 - Key length—Predetermined length for the key. The longer the key, the more difficult it is to compromise in a brute force attack where all possible key combinations are tried.

Key Elements of Cryptographic Systems

- Effective cryptographic systems depend upon a variety of factors including:
 - Algorithm strength
 - Secrecy and difficulty of compromising a key
 - Nonexistence of back doors by which an encrypted file can be decrypted without knowing the key
 - Inability to decrypt parts of a ciphertext message and prevent known plaintext attacks
 - Properties of the plaintext known by a perpetrator

Key Systems

- There are two types of cryptographic systems:
 - Symmetric Key Systems—These use single, secret, bidirectional keys that encrypt and decrypt.
 - Asymmetric Key Systems—These use pairs of unidirectional, complementary keys that only encrypt or decrypt. Typically, one of these keys is secret, and the other is publicly known.
- Public key systems are asymmetric cryptographic systems.
 - Most encrypted transactions over the Internet use a combination of private/public keys, secret keys, hash functions (fixed values derived mathematically from a text message) and digital certificates (that prove ownership of a public encryption key).
- Essentially, keys and hash values are used to transform a string of characters into a shorter or fixed-length value or key that represents the original string.
- This encryption process allows data to be stored and transported with reduced exposure so data remains secure as it moves across the Internet or other networks.

Encryption Techniques

- Symmetric (Private) Key Encryption
 - Symmetric key cryptographic systems are based on a symmetric encryption algorithm, which uses a secret key to encrypt the plaintext to the ciphertext and the same key to decrypt the ciphertext to the corresponding plaintext.
 - In this case, the key is said to be symmetric because the encryption key is the same as the decryption key.
 - The most common symmetric key cryptographic system is the Data Encryption Standard (DES).
 - DES is based on a public algorithm that operates on plaintext in blocks (strings or groups) of bits. This type of algorithm is known as a block cipher. DES uses blocks of 64 bits.
 - DES is no longer considered a strong cryptographic solution because its entire key space can be forced when every key is tried by large computer systems within a relatively short period of time.
 - DES is being replaced with AES, a public algorithm that supports keys from 128 bits to 256 bits.

Encryption Techniques

- Symmetric (Private) Key Encryption
 - There are two main advantages to symmetric key cryptosystems such as DES or AES:
 - The user only has to remember/know one key for both encryption and decryption.
 - Symmetric key cryptosystems are generally less complicated and, therefore, use up less processing power than asymmetric techniques. They are ideally suited for bulk data encryption.
 - The disadvantages of this approach include:
 - Difficulty distributing keys—Getting the keys into the hands of those with whom you want to exchange data can be a challenge, particularly in e-commerce environments where customers are unknown, untrusted entities.
 - Limitations of shared secret—A symmetric key cannot be used to sign electronic documents or messages due to the fact that the mechanism is based on a shared secret.

Encryption Techniques

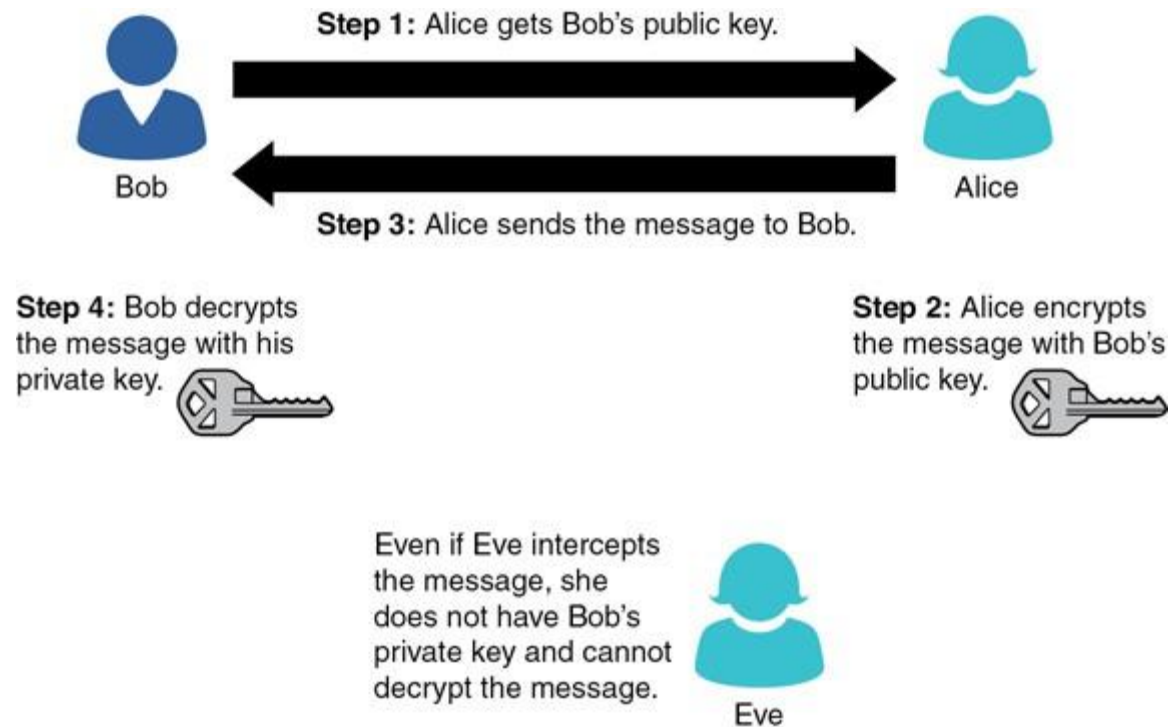
- Asymmetric (Public) Key Encryption
 - Public key cryptographic systems developed for key distribution solve the problem of getting single symmetric keys into the hands of two people who do not know each other but who want to exchange information securely.
 - Based on an asymmetric encryption process, two keys work together as a pair. One key is used to encrypt data; the other is used to decrypt data.
 - Either key can be used to encrypt or decrypt, but once the key has been used to encrypt data, only its partner can be used to decrypt the data.
 - The key that was used to encrypt the data cannot be used to decrypt it. Thus, the keys are asymmetric in that they are inversely related to each other.

Encryption Techniques

- Asymmetric (Public) Key Encryption
 - Based on mathematical integer factorization, asymmetric keys generate a single product from two large prime numbers, making it impractical to factor the number and recover the two factors.
 - This integer factorization process forms the basis for public key cryptography, a function that is easy to compute in one direction but very difficult or impractical in the other.
 - The system involves modular arithmetic, exponentiation and large prime numbers thousands of bits long.
 - Asymmetric keys are often used for short messages such as encrypting DES symmetric keys or creating digital signatures.
 - If asymmetric keys were used to encrypt bulk data (long messages), the process would be very slow; this is the reason they are used to encrypt short messages such as digests or signatures.

Encryption Techniques

- Asymmetric (Public) Key Encryption



Encryption Techniques

- Elliptical Curve Cryptography
 - Although public key cryptography ensures message security, the long keys and mathematical problems it uses tend to be inefficient.
 - A variant and more efficient form of public key cryptography is elliptical curve cryptography (ECC), which is gaining prominence as a method for increasing security while using minimum resources.
 - It is believed that ECC demands less computational power and therefore offers more security per bit.
 - For example, an ECC with a 160-bit key offers the same security as an RSA-based system with a 1,024-bit key.
 - ECC works well on networked computers requiring strong cryptography. However, it has some limitations such as bandwidth and processing power.

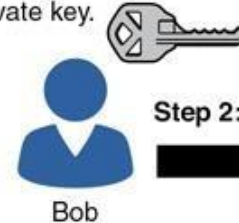
Advanced Encryption Standard

- AES has replaced the DES as the cryptographic algorithm standard. It originated in 1997, when NIST announced the initiation of the AES development effort and made a formal call for algorithms.
- For AES the block length was fixed to 128 bits, and three different key sizes (128, 192 and 256 bits) were specified. Therefore, AES-128, AES-192 and AES-256 are three different versions of AES.
- The cipher is based on substitution bytes, shifting rows, mixing columns and adding round keys that are repeated for 10 rounds.
- Each round has a 128-bit round key and the result of the previous round as input. The round keys can be precomputed or generated out of the input key. Due to its regular structure, it can be implemented efficiently in hardware.
- Decryption is computed by applying inverse functions of the round operations. The sequence of operations for the round function differs from encryption, which often results in separated encryption and decryption circuits.

Digital Signature

- A digital signature is not used to ensure the confidentiality of a message but rather to guarantee who sent the message.
- This is referred to as nonrepudiation. Essentially, nonrepudiation means proving who the sender is.
- Digital signatures are actually rather simple, but they are clever. They simply reverse the asymmetric encryption process.
- With a digital signature, the sender encrypts something with his private key. If the recipient is able to decrypt that with the sender's public key, then it must have been sent by the person purported to have sent the message

Step 1: Bob signs the message with his private key.



Step 2: Bob sends the message with a signature.



Step 3: Alice verifies the signature using Bob's public key.



Hashing

- A hashing is a type of cryptographic algorithm that has some specific characteristics. First and foremost, it is one way. That means you cannot unhash something.
- Second, you get a fixed-length output no matter what input is given.
- Third, there are no collisions. A collision occurs when two different inputs to the same hashing algorithm produce the same output (called a hash or digest). Ideally we would like to have no collisions.
- Hashes are exactly how Windows stores passwords. For example, if your password is password, then Windows will first hash it and produce something like this:

0BD181063899C9239016320B50D3E896693A96DF

- Windows will then store that in the SAM (Security Accounts Manager) file in the Windows System directory. When you log on, Windows cannot unhash your password (because, remember, it is one way). So, what Windows does is take whatever password you type in, hash it, and then compare the result with what is in the SAM file. If they match (exactly), then you can log in.

Hashing

- MD5
 - MD5 is a 128-bit hash that is specified in RFC 1321. It was designed by Ron Rivest in 1991 to replace an earlier hash function, MD4. MD5 produces a 128-bit hash or digest. It has been found to be not as collision resistant as SHA.
- SHA
 - Secure Hash Algorithm (SHA) is perhaps the most widely used hash algorithm today. There are now several versions of SHA. All versions of SHA are considered to be secure and collision free:
 - SHA-1: This is a 160-bit hash function that resembles the earlier MD5 algorithm. It was designed by the NSA to be part of the Digital Signature Algorithm (DSA).
 - SHA-2: This is actually two similar hash functions, with different block sizes, known as SHA-256 and SHA-512. They differ in the word size; SHA-256 uses 32-byte (256 bits) words, whereas SHA-512 uses 64-byte (512 bits) words. There are also truncated versions of each standardized, known as SHA-224 and SHA-384. These were also designed by the NSA.
 - SHA-3: This latest version of SHA was adopted in October 2012.

Steganography

- Steganography is the art and science of writing hidden messages in such a way that no one, apart from the sender and intended recipient, suspects the existence of the message.
- It is a form of security through obscurity. Often the message is hidden in some other file, such as a digital picture or an audio file, to defy detection.
- The advantage of steganography over cryptography alone is that messages do not attract attention to themselves. If someone is aware that a message is even there, she won't try to decipher it. In many cases, messages are encrypted and hidden via steganography.
- The most common implementation of steganography utilizes the least significant bits in a file in order to store data. By altering the least significant bit, you can hide additional data without altering the original file in any noticeable way.

Cryptography on the Internet

- Secure transport
 - In general, symmetric algorithms are faster and require a shorter key length to be as secure as asymmetric algorithms.
 - However, there is the problem of how to securely exchange keys. So most e-commerce solutions use an asymmetric algorithm to exchange symmetric keys and then use the symmetric keys to encrypt the actual data.
 - When visiting websites that have an HTTPS at the beginning rather than HTTP, the S denotes Secure.
 - It means traffic between your browser and the web server is encrypted—usually with either SSL (Secure Sockets Layer) or TLS (Transport Layer Security). Both SSL and TLS are asymmetric systems.

Cryptography on the Internet

- Virtual Private Network
 - A VPN is an example of applied cryptography that typically exchanges secure data over the Internet.
 - Encryption is needed to make the connection virtually private. A popular VPN technology is IPSec, which commonly uses the DES, Triple DES or AES encryption algorithms.
- Wireless Network Protections
 - Wireless data transmission is subject to a higher risk of interception than wired traffic, in the same way that it is easier to intercept calls made from cell phones than calls from landline telephones.
 - There is no need to manually tap into the connection, but rather remote tools can be used to intercept the connection covertly. Wireless transmission of confidential information should be protected with strong encryption.

Digital Certificates

- The digital certificate contains the user's public key, along with other information.
- However, a digital certificate can provide much more. It can provide a means for authenticating that the holder of the certificate is who she claims to be.
- X.509 is an international standard for the format and information contained in a digital certificate.
- X.509 is the most common type of digital certificate in the world. It is a digital document that contains a public key signed by the trusted third party that is known as a certificate authority, or CA.

Digital Certificates

- The following are the basic items in an X.509 certificate, though there can be other optional information:
 - Version: This is the version of X.509 that this certificate complies with.
 - Certificate holder's public key: This is the primary way of getting someone's public key from his X.509 certificate.
 - Serial number: This is a unique identifier for this certificate.
 - Certificate holder's distinguished name: This is often a domain name or an email address associated with a certificate.
 - Certificate's validity period: One year is the most common validity period.
 - Unique name of certificate issuer: This is the certificate authority that issued this certificate.
 - Digital signature of issuer: This field and the next are used to verify the certificate.
 - Signature algorithm identifier: This identifies the digital signature algorithm used.

Digital Certificates

- Let us see how this works in a common scenario. Say that you visit your bank's website. In order to get the bank's public key, your browser will download that bank's digital certificate.
- But there is a problem. Could someone have set up a fake site, claiming to be your bank? Could that person have also generated a fake certificate, claiming to be the bank? Yes, it's possible.
- This is one place digital certificates help us out. Your browser will look at the certificate issuer listed on the certificate and first ask if that is a CA that your browser trusts.
- If it is, then your browser communicates with that CA to get that CA's public key. The browser uses that CA public key to verify the CA signature on the certificate.
- If this is a fake certificate, the digital signature won't be recognized. This means a certificate not only provides you with the certificate holder's public key but also gives you a method of verifying that entity with a trusted third party.

SSL/TLS

- When visiting websites that have an HTTPS at the beginning, rather than HTTP, the S denotes Secure.
- It means traffic between your browser and the web server is encrypted—usually with either SSL (Secure Sockets Layer) or TLS (Transport Layer Security).
- SSL and TLS are both asymmetric systems.
- SSL, the older of the two technologies, is used to allow for transport-layer security via public key encryption.

